# INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

## GRC103

# RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

### MODULE 3 | RISK TREATMENT STRATEGIES

## TECHNICAL RISK TREATMENT LAB

*Implementing and Validating Controls on a Local Linux Server*

| SUBMISSION DETAIL | INFORMATION |
|---|---|
| Student | Kefilwe Matake |
| Registration Number | C11_26_CGRCE_17575 |
| Role | GRC Analyst and Technical Control Implementer |
| Assessment | Module 3 Technical Risk Treatment Lab |
| Organisation | Northbridge Services (Fictional) |
| Report Date | 07 November 2026 |
| Submission Package | Technical Risk Treatment Report and Evidence Package |

# Contents


- Executive Summary
- 1. Lab Environment Overview
- 2. Baseline Environment Construction
- 3. Baseline Risk Assessment
- 4. Baseline Evidence Collection
- 5. Risk Avoidance Strategy
- 6. Preventive Control Implementation
- 7. Detective Control Validation
- 8. Corrective Control and Recovery Testing
- 9. Risk Transfer Strategy Assessment
- 10. Risk Acceptance Assessment
- 11. Cost-Benefit Analysis
- 12. Quantitative Backup Analysis
- 13. Residual Risk Register
- 14. Monitoring and Operational Handover
- 15. Management Conclusion
- Appendix A – Evidence Register
- Appendix B – Assumptions and Limitations

# Executive Summary

Northbridge Services (a fictional organisation used for this assessment) required practical risk treatment measures to reduce unnecessary exposure while preserving the availability of an approved internal web portal. A controlled laboratory environment was established using Ubuntu Server and Kali Linux on an isolated host-only network. The exercise focused on implementing, validating and reviewing technical controls across the service, application, network, logging and recovery layers.

The baseline assessment identified four principal risks: an unnecessary legacy service, publicly accessible archive content, insufficient network access restrictions, and the potential loss of critical portal content. The treatment activities included retiring the legacy service, removing archive content from the web-accessible directory, restricting inbound traffic through UFW, validating application and firewall logging, and testing backup restoration.

The results indicate that the selected controls reduced the tested attack surface while maintaining access to the approved portal from the authorised laboratory client. Recovery testing also demonstrated that the portal homepage could be restored from a backup in 6 minutes and 50 seconds. This result represents a same-host recovery test and should not be interpreted as proof of disaster recovery capability.

| Executive Measure | Outcome |
|---|---|
| Primary risks assessed | 4 |
| Legacy service retirement | Completed; TCP/8080 no longer available in the tested state |
| Archive exposure treatment | Completed; archive requests returned HTTP 403 |
| Network access restriction | Implemented and validated against authorised and unauthorised source IPs |
| Logging validation | Completed for application requests and firewall-denied traffic |
| Backup and restoration test | Completed; file integrity hash matched |
| Residual risk position | Low to moderate based on the supplied residual scores |
| Overall treatment approach | Avoid, mitigate, transfer and accept, as applicable |

**OVERALL RESULT**
The laboratory objectives were achieved within the stated test environment. Continued monitoring, periodic control testing and stronger off-host backup arrangements are recommended before any production deployment.

# 1. Lab Environment Overview

## 1.1 Infrastructure Configuration

The laboratory consisted of two virtual machines connected through an isolated host-only network. Ubuntu Server hosted the web portal and the controls under assessment, while Kali Linux acted as the authorised test client and, where required, an unauthorised-source simulation.

| Component | Configuration / Purpose |
|---|---|
| Ubuntu Server | Ubuntu Server 24.04 LTS; target server hosting the portal |
| Kali Linux | Latest Kali Linux release; authorised testing client |
| Web service | NGINX |
| Host firewall | Uncomplicated Firewall (UFW) |
| Legacy service | Python HTTP service managed through systemd |
| Internal network | 192.168.56.0/24 – isolated host-only network |

## 1.2 Recorded Laboratory Addresses

| Device | IP Address |
|---|---|
| Ubuntu Server | 192.168.56.20 |
| Kali Linux | 192.168.56.10 |
| Simulated unauthorised client | 192.168.56.11 |

The addresses above reflect the values recorded in the supplied lab notes. The unauthorised client address was used to validate the firewall policy and should be understood as a simulated source within the lab.

# 2. Baseline Environment Construction

## 2.1 Creation of Laboratory Content

A directory structure was created to represent an internal web portal, a document archive and a legacy service location. The content consisted of fictional training records and did not contain real organisational or personal information.

```
/var/www/grc-lab/public
/var/www/grc-lab/archive
/srv/grc-legacy
```

- Approved internal portal content was placed in the public web directory.
- Dummy archive records were created to test unintended information exposure.
- A legacy training endpoint was prepared to represent an unnecessary service.

**EVIDENCE PLACEHOLDER — CREATION OF LABORATORY DIRECTORIES AND FILES**

```
┌──(icdfa㉿icdfa)-[~]
└─$ sudo mkdir -p /var/www/grc-lab/public /var/www/grc-lab/archive /srv/grc-legacy
printf 'Approved internal portal\n' | sudo tee /var/www/grc-lab/public/index.html
printf 'DUMMY RECORD A001 - training only\n' | sudo tee /var/www/grc-lab/archive/dummy-records.txt
printf 'Legacy training endpoint\n' | sudo tee /srv/grc-legacy/index.html
sudo chmod -R a+rX /var/www/grc-lab /srv/grc-legacy
Approved internal portal
DUMMY RECORD A001 - training only
Legacy training endpoint
```

## 2.2 Legacy Service Deployment

A Python HTTP server was deployed on TCP port 8080 and configured as a systemd service. The service was intentionally enabled for the baseline assessment so that its exposure could be identified and treated.

**EVIDENCE PLACEHOLDER — SYSTEMD LEGACY SERVICE DEPLOYMENT**

```
┌──(icdfa㉿icdfa)-[~]
└─$ sudo tee /etc/systemd/system/grc-legacy.service > /dev/null <<'EOF'
[Unit]
Description=GRC lab legacy endpoint
[Service]
User=www-data
ExecStart=/usr/bin/python3 -m http.server 8080 --bind 0.0.0.0 --directory /srv/grc-legacy
[Install]
WantedBy=multi-user.target
EOF
sudo systemctl daemon-reload
sudo systemctl enable --now grc-legacy
Created symlink '/etc/systemd/system/multi-user.target.wants/grc-legacy.service' → '/etc/systemd/system/grc-legacy.service'.
```

## 2.3 NGINX Portal Configuration

NGINX was configured to serve the approved internal portal. Directory listing was enabled for the initial baseline so that the assessment could demonstrate the risk associated with exposing archive content through a web server.

**EVIDENCE PLACEHOLDER — NGINX BASELINE CONFIGURATION**

```
┌──(icdfa㉿icdfa)-[~]
└─$ sudo tee /etc/nginx/sites-available/grc-lab > /dev/null <<'EOF'
server {
    listen 80;
    server_name _;
    root /var/www/grc-lab;
    access_log /var/log/nginx/grc_access.log combined;
    error_log /var/log/nginx/grc_error.log;
    location / { autoindex on; }
}
EOF
sudo ln -s /etc/nginx/sites-available/grc-lab /etc/nginx/sites-enabled/grc-lab
sudo rm -f /etc/nginx/sites-enabled/default
sudo nginx -t && sudo systemctl reload nginx
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
nginx.service is not active, cannot reload.
```

## 3. Baseline Risk Assessment

The initial risk assessment considered the asset, threat event and weakness associated with each scenario. Likelihood and impact were scored on a 1–5 scale, with the risk score calculated as Likelihood × Impact. The rating labels below follow the supplied assessment results; the organisation should formally document its scoring thresholds in a production risk methodology.

| ID / Risk | Asset and Threat Event | Key Weakness | L | I | Score | Initial Rating | Owner |
|---|---|---|---|---|---|---|---|
| R1 – Legacy service exposure | Legacy endpoint; unauthorised access | Unused service running | 4 | 4 | 16 | High | System Administrator |
| R2 – Public archive exposure | Dummy records; information disclosure | Public directory listing / web-accessible archive | 4 | 3 | 12 | High | Web Administrator |
| R3 – Unauthorised network access | Web portal; unauthorised connection | No effective source restriction at baseline | 4 | 4 | 16 | High | Infrastructure Team |
| R4 – Loss of portal content | Portal homepage; accidental deletion | Recovery process not verified | 3 | 4 | 12 | High | Infrastructure Team |

**RISK SCORING**
Scores are calculated as likelihood multiplied by impact. The 1–5 scale and the supplied High ratings are retained for consistency with the lab material. Confirm and document the rating bands before applying this register to a real organisation.

## 4. Baseline Evidence Collection

Baseline tests were completed before control implementation to establish the initial state of the environment. The tests focused on service reachability, portal availability and the accessibility of archive content.

| Baseline Test | Observed Result |
|---|---|
| TCP port 80 | Reachable |
| TCP port 8080 | Reachable |
| Approved portal | Available |
| Archive directory listing | Available |
| Dummy archive file download | Available |

The results confirmed that both the approved web service and the unnecessary legacy service were reachable from the test client. Archive content was also accessible before treatment, supporting the identification of the exposure risks.

**EVIDENCE PLACEHOLDER — BASELINE SCAN AND CONNECTIVITY TEST**

```
┌──(icdfa㉿icdfa)-[~]
└─$ mkdir -p ~/grc-treatment-evidence
cd ~/grc-treatment-evidence
SERVER_IP=192.168.56.20  # replace with your Ubuntu address
date -Is | tee baseline-time.txt
nmap -sT -p 80,8080 "$SERVER_IP" -oN baseline-ports.txt
curl -i "http://$SERVER_IP/" | tee baseline-web.txt
curl -i "http://$SERVER_IP/archive/" | tee baseline-listing.txt
curl -i "http://$SERVER_IP/archive/dummy-records.txt" | tee baseline-file.txt
curl -i "http://$SERVER_IP:8080/" | tee baseline-legacy.txt
2026-11-07T13:01:44+01:00
Starting Nmap 7.95 ( https://nmap.org ) at 2026-11-07 13:01 WAT
Nmap scan report for 192.168.56.20
Host is up (0.0011s latency).

PORT     STATE    SERVICE
80/tcp   filtered http
8080/tcp filtered http-proxy

Nmap done: 1 IP address (1 host up) scanned in 1.46 seconds
curl: (7) Failed to connect to 192.168.56.20:80 after 21005 ms: Could not connect to server
curl: (7) Failed to connect to 192.168.56.20:80 after 21004 ms: Could not connect to server
```

# 5. Risk Avoidance Strategy

## 5.1 Retirement of the Legacy Endpoint

Risk avoidance was applied by retiring a service that was not required to deliver the approved portal functionality. Removing the service eliminated the unnecessary listening endpoint rather than attempting to secure a business-unnecessary service.

| Change Item | Details |
|---|---|
| Proposed action | Retire the legacy service while retaining the approved NGINX portal. |
| Business impact | No expected impact on the approved portal; reduced attack surface and maintenance overhead. |
| Approval status | Simulated approval for academic laboratory purposes. |
| Rollback procedure | Re-enable and start the service if restoration is authorised and required. |

```
sudo systemctl disable --now grc-legacy

sudo systemctl enable --now grc-legacy   # rollback command
```

The service was disabled and stopped. Post-change validation indicated that TCP port 8080 was no longer available in the tested environment.

**EVIDENCE PLACEHOLDER — LEGACY SERVICE RETIREMENT**

```
┌──(icdfa㉿icdfa)-[~/grc-treatment-evidence]
└─$ sudo systemctl disable --now grc-legacy
sudo systemctl is-active grc-legacy
sudo ss -lntp
Removed '/etc/systemd/system/multi-user.target.wants/grc-legacy.service'.
inactive
State                Recv-Q               Send-Q                              Local Address:Port                              Peer Address:Port               Process

┌──(icdfa㉿icdfa)-[~/grc-treatment-evidence]
└─$
```

Risk treatment result: the specific exposure created by the unnecessary legacy endpoint was removed. This does not eliminate other risks affecting the active portal or the underlying host.

# 6. Preventive Control Implementation

## 6.1 Archive Hardening

The archive directory was moved outside the NGINX web root, reducing the possibility of direct public retrieval. The web configuration was also hardened by disabling directory listing and applying an explicit denial rule where appropriate.

- Archive content was removed from the public web directory.
- Directory listing was disabled.
- Direct requests to the archive path and known dummy file were denied.

| Validation Target | Observed Result |
|---|---|
| /public/ | HTTP 200 – approved content accessible |
| /archive/ | HTTP 403 – access denied |
| dummy-records.txt | HTTP 403 – access denied |

A key security consideration is that disabling directory listing alone does not prevent a user from requesting a file when its name is known. Relocating the archive outside the web root provides the stronger control because the files are no longer directly addressable through the web server.

### 6.2 Firewall Restriction

UFW was configured to deny unsolicited inbound connections by default and permit HTTP traffic from the approved Kali Linux client only. This created a source-based access restriction for the portal within the isolated laboratory network.

```
sudo ufw default deny incoming
sudo ufw allow from 192.168.56.10 to any port 80
```

The rule set was intended to allow the approved test source while blocking other source addresses. The legacy service on TCP port 8080 had already been retired.

| Source / Service | Expected / Observed Outcome |
|---|---|
| 192.168.56.10 to TCP/80 | Allowed |
| 192.168.56.11 to TCP/80 | Blocked / timed out |
| TCP/8080 | Unavailable following service retirement |

### 6.3 Blocked-Source Validation

A second source address was used to simulate an unauthorised client. The test confirmed that the approved client could reach the portal while the unauthorised source did not receive a connection.

| Source Address | Test Outcome |
|---|---|
| 192.168.56.10 | Allowed |
| 192.168.56.11 | Timed out / blocked |

## 7. Detective Control Validation

### 7.1 Log Correlation

Logging was reviewed to confirm that application-layer requests and network-layer blocks were recorded at the appropriate control points. Requests permitted through the firewall should be visible in NGINX access logs. Requests denied by UFW are filtered before reaching NGINX and should therefore be recorded in firewall/UFW logs rather than the NGINX access log.

| Event | Expected Log Location |
|---|---|
| Allowed web request | NGINX access log |
| Archive access denial (HTTP 403) | NGINX access log |
| Firewall-denied connection | UFW / kernel firewall log, subject to logging configuration |
| Authorised portal session/request | NGINX access log |

### 7.2 Test Evidence

| Test ID | Source IP | Requested Resource | Expected Result | Recorded Result |
|---|---|---|---|---|
| T01 | 192.168.56.10 | /public | Allow | Successful |
| T02 | 192.168.56.10 | /archive | Deny | HTTP 403 |
| T03 | 192.168.56.11 | /public | Block | Timeout |
| T04 | 192.168.56.10 | Portal access | Log request | Logged |

The test results support the operation of the preventive controls and the expected separation between application logging and firewall logging. For a production environment, centralised log collection, time synchronisation, retention controls and alerting should also be considered.

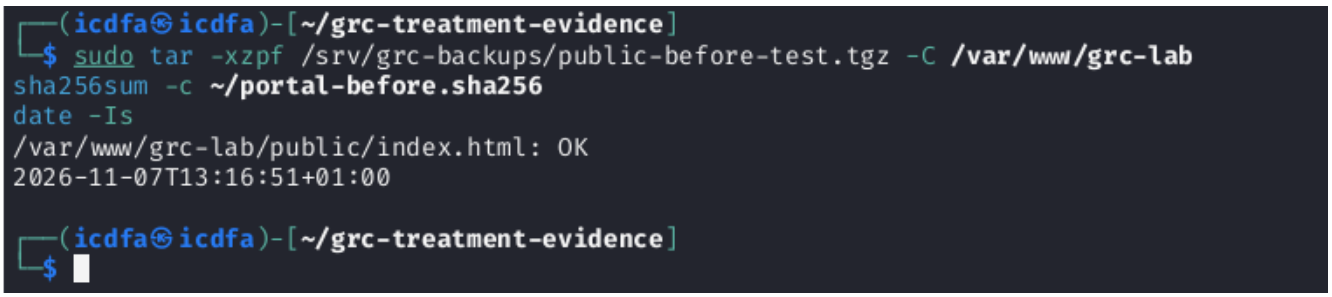
## 8. Corrective Control and Recovery Testing

### 8.1 Backup Creation

A protected backup directory was created and a backup archive of the portal content was generated. A SHA-256 hash was calculated to provide an integrity reference for subsequent restoration validation.

- A dedicated backup location was created.
- The portal content was archived.
- A SHA-256 checksum was recorded for integrity verification.

**EVIDENCE PLACEHOLDER — BACKUP CREATION AND HASHING**




### 8.2 Recovery Validation

To test the recovery procedure, the portal homepage was intentionally removed. The resulting service/content failure was confirmed, after which the homepage was restored from the backup. The restored file was checked against the recorded hash and portal availability was revalidated.

| Recovery Activity | Result |
|---|---|
| Backup created | Successful |
| Portal homepage removed | Successful (test condition established) |
| Content/service failure confirmed | Successful |
| File restored from backup | Successful |
| SHA-256 integrity comparison | Matched / verified |
| Portal availability after restoration | Restored |

| Recovery Metric | Recorded Value |
|---|---|
| Start time | 07 November 2026, 13:10:01 |
| End time | 07 November 2026, 13:16:51 |
| Observed recovery duration | 6 minutes 50 seconds |

The test demonstrated successful same-host restoration for the selected portal file. The measured recovery duration is an observed result from this exercise; it is not a formally approved Recovery Time Objective (RTO).

**RECOVERY LIMITATION**
A backup stored on the same host may be lost or compromised alongside the source system. The test did not demonstrate recovery from hardware failure, ransomware, complete server loss or a site-level disaster. Off-host, immutable or otherwise isolated backups and periodic recovery exercises are recommended.

# 9. Risk Transfer Strategy Assessment

## 9.1 Managed Backup Service Assessment

A managed backup service was considered as a risk-transfer measure. Outsourcing backup storage and platform maintenance may reduce selected operational risks, but it does not transfer the organisation's accountability for data ownership, recovery objectives, supplier oversight or business continuity.

| Cost Component | Assumed Cost |
|---|---|
| One-time setup fee | US$120 |
| Monthly subscription | US$20 |
| Annual subscription (12 × US$20) | US$240 |
| First-year total | US$360 |

| Provider Responsibilities | Customer Responsibilities |
|---|---|
| Provide and maintain the backup storage platform | Retain data ownership and define recovery requirements |
| Maintain the contracted backup service | Review backup reports and monitor service performance |
| Support agreed recovery capabilities | Conduct restoration tests and validate recovered data |
| Meet agreed contractual security requirements | Retain evidence and oversee supplier risk |

## 9.2 Proposed Contractual Clause

**PROPOSED SERVICE CLAUSE**
Northbridge Services shall conduct restoration tests at least quarterly and retain evidence of successful recovery validation. The service provider shall maintain the contracted backup platform and meet agreed security, availability and retention obligations. Use of a managed backup service does not remove Northbridge Services' responsibility for data governance, recovery planning, supplier oversight or business continuity.

The quoted costs are laboratory assumptions and should be validated through supplier due diligence, service-level review and a formal procurement process before any real-world commitment.

# 10. Risk Acceptance Assessment

## 10.1 Temporary HTTP Usage

A limited residual risk associated with temporary HTTP usage was assessed for acceptance within the isolated laboratory environment. This acceptance is conditional and applies only to the fictional, temporary test scenario.

| Acceptance Field | Recorded Value |
|---|---|
| Risk owner | IT Operations Manager |
| Residual risk score | 6 |
| Approval status | Simulated – academic exercise |
| Review date | 14 days after acceptance |
| Acceptance basis | Isolated laboratory environment only |

The acceptance rationale was based on the isolation of the host-only network, the use of fictional data, the absence of internet exposure and the temporary nature of the environment.

### 10.2 Escalation and Reassessment Triggers

- Introduction of real or sensitive data.
- Exposure of the service to the internet or an untrusted network.
- Deployment into a production environment.
- Expansion of access to additional users or systems.

**ACCEPTANCE CONDITION**
Risk acceptance must be time-bound, documented and approved by an authorised risk owner. If any escalation trigger occurs, the risk must be reassessed and appropriate encryption and access controls implemented. HTTP should not be accepted for production use where credentials or sensitive information may be transmitted.

## 11. Cost-Benefit Analysis

The following estimates were supplied for the laboratory exercise. They are treated as illustrative planning assumptions rather than verified market quotations.

| Control Option | Cost Calculation | First-Year Cost |
|---|---|---|
| Option A – Hardening | 4 hours × US$25 = US$100 labour; US$50 annual maintenance | US$150 |
| Option B – Managed backup | US$120 setup + (12 × US$20 subscription) | US$360 |
| Option C – TLS deployment | 3 hours × US$25 = US$75 labour; US$25 maintenance | US$100 |

### 11.1 Recommended Control Portfolio

| Control | First-Year Cost |
|---|---|
| Hardening | US$150 |
| Managed backup | US$360 |
| TLS deployment | US$100 |
| Total estimated first-year cost | US$610 |

The recommended portfolio combines preventive hardening, improved backup resilience and encryption in transit. TLS deployment is included as a proposed control option in the cost model; it is not represented as an implemented or validated control in the lab results provided.

Excluded costs include staff training, future hardware, external consultancy and incident response. Additional costs may arise from monitoring, certificate lifecycle management, storage growth and supplier assurance.

## 12. Quantitative Backup Analysis

The Annualised Loss Expectancy (ALE) calculation estimates the annualised financial exposure before and after the proposed backup treatment. All figures in this section are assumptions supplied by the laboratory scenario.

| Measure | Baseline | Residual |
|---|---|---|
| Annual Rate of Occurrence (ARO) | 0.2 | 0.2 |
| Estimated loss per event | US$5,000 | US$1,000 |
| ALE calculation | 0.2 × US$5,000 | 0.2 × US$1,000 |
| Annualised Loss Expectancy | US$1,000 | US$200 |

### 12.1 Estimated Annual Benefit

Estimated annual risk reduction benefit = Baseline ALE − Residual ALE.

**CALCULATED BENEFIT**
US$1,000 − US$200 = US$800 estimated annual benefit.

### 12.2 First-Year Net Benefit

First-year net benefit = Estimated annual benefit − First-year managed backup cost.

**FIRST-YEAR NET BENEFIT**
US$800 − US$360 = US$440 estimated first-year net benefit.

This simplified model assumes the stated ARO remains constant and that the backup control reduces the loss per event to US$1,000. It excludes implementation risk, indirect costs, discounting and uncertainty in the estimates. The result should therefore be treated as an indicative business-case calculation, not a guaranteed saving.

## 13. Residual Risk Register

Residual scores reflect the post-treatment values supplied for the exercise. A closed risk indicates that the specific scenario has been addressed in the lab; it does not mean that the associated asset is free from all security risk.

| Risk | Initial Score | Residual Score | Status | Ongoing Consideration |
|---|---|---|---|---|
| R1 – Legacy endpoint | 16 | 2 | Closed for lab scenario | Monitor for service re-enablement or configuration drift. |
| R2 – Archive exposure | 12 | 3 | Controlled | Review web-root contents and access rules. |
| R3 – Unauthorised access | 16 | 4 | Controlled | Review firewall rules and authorised source list. |
| R4 – Portal content loss | 12 | 4 | Controlled | Maintain off-host backups and repeat recovery tests. |

The residual scores indicate a reduction in the assessed risks. The risk owner should formally review and approve the residual position, particularly where the organisation's risk appetite or scoring thresholds have not been defined in the lab documentation.

## 14. Monitoring and Operational Handover

The following monitoring activities are recommended to sustain the controls after implementation. The frequency, thresholds and escalation roles are based on the supplied lab plan.

| Control / Activity | Owner | Frequency | Trigger / Threshold | Escalation |
|---|---|---|---|---|
| Portal availability | System Administrator | Daily | Service unavailable | IT Manager |
| Unexpected open ports | Security Team | Weekly | New or unauthorised listening port | Security Lead |
| Recovery test | Infrastructure Team | Quarterly | Failed restoration or integrity mismatch | Operations Manager |
| Legacy service drift check | Security Team | Weekly | Legacy service running or re-enabled | Security Lead |

### 14.1 Handover Requirements

- Assign a named owner to each control and retain evidence of ownership.
- Keep firewall rules, NGINX configuration and service inventories under change control.
- Review logs regularly and define alerting for repeated denied connections or unexpected service changes.
- Maintain backup copies outside the source host and protect them from unauthorised alteration.
- Perform quarterly restoration tests and document actual recovery time and data integrity results.
- Reassess residual risks when the environment, data classification or network exposure changes.

## 15. Management Conclusion

The laboratory demonstrated the application of the four risk treatment strategies covered in Module 3. Risk avoidance was applied by retiring an unnecessary legacy service. Risk mitigation was implemented through archive hardening,

firewall restrictions and logging validation. Risk transfer was evaluated through a managed backup service model, while risk acceptance was documented for temporary HTTP usage under tightly controlled laboratory conditions.

The validation activities indicated that the approved portal remained accessible to the authorised client, archive content was denied through the web interface, unauthorised source traffic was blocked, and the portal homepage was successfully restored from backup. The recovery test completed in 6 minutes and 50 seconds, with the integrity check reported as successful.

The results support the conclusion that the stated risk treatment objectives were achieved for the controlled lab scenario. Before applying these measures in a production environment, Northbridge Services would need to formalise risk scoring thresholds and approvals, deploy TLS, implement off-host and resilient backups, strengthen centralised monitoring, and conduct ongoing control assurance.

**OVERALL ASSESSMENT**
Risk treatment objectives achieved within the scope and limitations of the laboratory exercise.

# Appendix A – Evidence Register

Insert the original screenshots, terminal outputs and configuration evidence at the relevant points in the report. Each item should be clearly labelled, dated where possible and linked to the test or control it supports.

| Evidence ID | Evidence Description | Report Section | Evidence to Attach |
|---|---|---|---|
| E01 | Directory and file creation | 2.1 | Directory listing / file creation output |
| E02 | Legacy service deployment | 2.2 | systemd unit and service status |
| E03 | NGINX baseline configuration | 2.3 | Configuration and service status |
| E04 | Baseline scan and connectivity | 4 | Port scan and HTTP access tests |
| E05 | Legacy service retirement | 5.1 | systemctl status and post-change scan |
| E06 | Archive hardening | 6.1 | Configuration and HTTP 200/403 responses |
| E07 | UFW access-control rules | 6.2 | UFW status and rule listing |
| E08 | Blocked-source validation | 6.3 | Authorised and unauthorised connection tests |
| E09 | Log correlation | 7 | NGINX and UFW/firewall log excerpts |
| E10 | Backup creation and hashing | 8.1 | Archive listing and SHA-256 output |
| E11 | Recovery validation | 8.2 | Restoration, hash comparison and portal check |

# Appendix B – Assumptions and Limitations

- Northbridge Services is a fictional organisation used solely for academic training.
- The lab network is an isolated host-only network using the addresses documented in this report.
- All archive records and portal content used in the exercise are fictional training data.
- Approval statuses described as simulated are not evidence of approval by a real organisation.
- Cost figures and ALE inputs are assumptions supplied by the lab and have not been independently validated.
- Evidence screenshots were referenced in the source material by description but were not included in the text supplied for document preparation. Evidence placeholders must be replaced with the original screenshots before submission.
- The recovery exercise demonstrated same-host file restoration only; it did not test full-system disaster recovery or off-site restoration.
- TLS is included as a recommended costed option but is not described as implemented because no implementation evidence was supplied.